

Esercizio Phishing

Obiettivo: Creare una simulazione di un'email di phishing utilizzando ChatGPT.

1. Scenario

Per questo esercizio ho deciso di evitare il classico attacco all'impiegato amministrativo e di alzare l'asticella: il mio target è il **Reparto IT (Sistemisti e Sviluppatori)**.

Perché questa scelta? Spesso si pensa che i tecnici siano immuni al phishing, ma anche loro possono cadere in trappola se l'email tocca i tasti giusti, come la paura di un disservizio (downtime) o la violazione di policy di sicurezza.

Obiettivo: L'obiettivo è il **Credential Harvesting**. Voglio spingere il tecnico a loggarsi su una finta pagina di autenticazione per "sbloccare" il suo account, rubandogli così username, password ed eventualmente intercettare il codice 2FA.

2. L'Email Generata

Come richiesto dalle istruzioni, ho utilizzato ChatGPT per generare il contenuto. Ho chiesto nello specifico di creare un alert che sembrasse provenire dal SOC (Security Operations Center) e che usasse una terminologia tecnica precisa per aumentare la credibilità.

Ecco il risultato ottenuto:

Oggetto: [CRITICAL] INCIDENT #9482: Rilevato accesso SSH anomalo / Revoca immediata token VPN **Mittente:** IT Security Ops <alert-noreply@infrastructure-status-update.com>

Ciao,

Il nostro sistema SIEM ha rilevato molteplici tentativi di connessione falliti via SSH verso l'ambiente di Produzione originati dal tuo account utente (IP: 192.168.x.x - *Outside Geo-fencing policy*).

In accordo con la policy di sicurezza ISO 27001 interna, il tuo certificato VPN e l'accesso SSO sono stati **messi in quarantena preventiva**.

Per evitare il lock-out completo dagli asset aziendali e ripristinare la sessione di lavoro, è necessario verificare l'attività e riconvalidare il token MFA immediatamente.

[Rivedi Log di Sicurezza e Ripristina Accesso]

Nota: Se non esegui la verifica entro 15 minuti, l'account verrà disabilitato a livello di Active Directory e sarà necessario l'intervento fisico del responsabile IT.

SOC Automated Response System Ticket ID: SEC-2024-9982

3. Analisi: Perché questa email potrebbe funzionare?

Ho analizzato i motivi per cui, secondo me, questo scenario rischia di ingannare anche un utente esperto:

- **Usa il linguaggio del target:** Non parla genericamente di "virus" o "fatture", ma cita protocolli specifici come *SSH*, *SIEM*, *SSO* e *Active Directory*. Questo abbassa le difese del tecnico perché il messaggio gli suona familiare e tecnicamente corretto.
- **Fa leva sull'orgoglio e la paura:** Nessun sistemista vuole essere tagliato fuori dai server ("lock-out completo") e, soprattutto, nessuno vuole dover chiamare il proprio capo ("intervento fisico del responsabile IT") per farsi riattivare l'account. È una situazione imbarazzante che si cerca di risolvere subito e in autonomia.
- **Sembra una procedura standard:** L'inserimento di un numero di Ticket e il riferimento alla norma ISO 27001 danno l'impressione che sia un normale processo burocratico automatizzato.

4. I "Campanelli d'Allarme" (Red Flags)

Rileggendo l'email con occhio critico, ci sono però diversi elementi che dovrebbero insospettire la vittima:

- **Il Mittente non è ufficiale:** L'indirizzo `alert-noreply@infrastructure-status-update.com` è sospetto. Un vero alert interno dovrebbe arrivare dal dominio aziendale (es. `@tua-azienda.it`), non da un dominio lungo e generico registrato esternamente.
- **La procedura è illogica:** Se il SOC rileva un attacco in corso, blocca l'account e basta. Non manda una mail chiedendo all'utente di cliccare un link per "auto-sbloccarsi". È una procedura di sicurezza che non ha senso nella realtà operativa.
- **La scadenza di 15 minuti:** È una classica tecnica di *Social Engineering* per mettere fretta e bypassare il ragionamento critico. I sistemi automatici (come Active Directory) solitamente non danno preavvisi così brevi via mail prima di disabilitare un utente.
- **Il Link:** Ovviamente, passando il mouse sopra il pulsante senza cliccare (hovering), si noterebbe che l'URL di destinazione non porta alla intranet aziendale, ma a un sito esterno malevolo.

5. Conclusione e Riflessioni

Questo esercizio mi ha fatto capire una cosa fondamentale: **nessuno è immune al phishing**, nemmeno chi lavora nel settore IT.

Spesso pensiamo che la formazione sulla sicurezza serva solo agli impiegati amministrativi, ma un attacco ben strutturato (*Spear Phishing*), che usa il linguaggio tecnico giusto e tocca le paure specifiche di un sistemista, può essere devastante. Anzi, colpire un tecnico è molto più rischioso per l'azienda, perché i suoi permessi di accesso sono solitamente molto più elevati rispetto a un utente standard.